

ET 8202: INTRODUCTION TO IS SECURITY

Lecture: 08

CYBER SECURITY THREAT LANDSCAPE

Saturday, January 13, 2024



Recap

- ❖ **Asset** is anything that has **value** to the organization, its business operations, and their continuity, including **Hardware, Software, and information (data)** resources that support the organization's mission.
- ❖ **Vulnerabilities:** A weakness in a system or its design that could be exploited by a threat.
- ❖ **Threats:** Any potential danger to an asset.
- ❖ **Risk:** Likelihood that a threat will exploit a vulnerability of an asset and result in an undesirable consequence. A situation involving **exposure** to danger, harm, or loss. Examples of risk include: Financial losses, Loss of privacy, Damage reputation, Legal implications, Even loss of life.



Security Controls

- ❖ At the most fundamental level, IT security is about protecting the organization's assets.
- ❖ Security controls exist to **reduce** or **mitigate** the risk to those assets.
- ❖ **Security controls** are countermeasures or safeguards used to reduce the chances that a threat will exploit a vulnerability.
 - ✓ They include any policy, procedure, technique, method, solution, plan, action, or device that eliminates or reduces a vulnerability.
- ❖ Once an organization defines **control objectives**, it can assess the risk to individual assets and then choose the most appropriate security controls to put in place.
 - ✓ **Control objectives:** statements about how the organization plans to effectively manage risk.

Security Controls Classification

1. By **Controls Type/Methods**:

- ✓ Physical control
- ✓ Technical control
- ✓ Administrative control

2. By **Controls Function**: the effective implementation of a security control is based on its classification in relation to the security incident.

- ✓ Preventative control
- ✓ Detective control
- ✓ Corrective control
- ✓ Deterrent controls
- ✓ Compensating controls

Controls Type/Methods: Physical Controls

- ❖ **Physical controls** describe anything tangible that's used to prevent or detect unauthorized access to physical areas, systems, or assets.
- ❖ Some common examples of physical controls are: fences, gates, locked and dead-bolted steel doors, security lighting, security badges and access cards, picture IDs, security guards, closed-circuit CCTV cameras, IP-based surveillance cameras, motion or thermal sensors/alarm systems, fire suppression systems/ fire extinguishers, biometric access controls (includes fingerprint, voice, face, iris, handwriting, and other automated methods used to recognize individuals), uninterruptible power supply (UPS) as well as environmental controls like HVAC (Heating, Ventilation, and Air Conditioning) and humidity controls. Also cabling, and work area separation.

Controls Type: Technical Controls

- ❖ **Technical controls** (also known as logical controls); technology based mechanisms (hardware or software) used to protect assets.
- ❖ Some common examples of technical controls are: Authentication solutions, firewalls, antivirus software, intrusion detection systems (IDSs), intrusion protection systems (IPSs), Honeypots, constrained interfaces, as well as access control lists (ACLs), encryption measures and Security Information and Event Management (SIEM)- a solution that helps organizations detect, analyze, and respond to security threats before they harm business operations.

Controls Type: Administrative Controls

- ❖ **Administrative controls** refer to policies, procedures, or guidelines that define personnel or business practices in accordance with the organization's security goals. It define the human factors of security.
- ❖ These can apply to employee hiring and termination, equipment and Internet usage, physical access to facilities, separation of duties, job rotation, mandatory vacation, data classification, and auditing.
- ❖ Security awareness training for employees also falls under the umbrella of administrative controls.

Control Functions: Preventative controls

- ❖ **Preventative controls** describe any security measure that's designed to stop unwanted or unauthorized activity from occurring.
- ❖ **Preventive controls** attempt to prevent an incident from occurring. Before a problem happens, when a risk is identified.
- ❖ **Examples include:**
 1. **Physical Preventative Controls:** fences, locks, badges, access cards, security guards and alarm systems
 2. **Technical Preventative Controls:** antivirus software, firewalls, and IPS- Intrusion Prevention System , Encryption, Multi-Factor Authentication (MFA) Solutions.
 3. **Administrative Preventative Controls:** Security Awareness Training, Account Disablement Policy, separation of duties, job rotation data classification, and hiring and termination policies.

Control Functions: Detective Controls

- ❖ **Detective controls** describe any security measure taken or solution that's implemented to detect and alert to unwanted or unauthorized activity in progress or after it has occurred.
- ❖ **Detective controls** attempt to detect incidents after they have occurred.
- ❖ Examples include:
 1. **Physical Detective Controls:** Alarms or notifications from physical sensor (door alarms, fire alarms) that alert guards, police, or system administrators, Motion Detection, Video Surveillance.
 2. **Technical Detective Controls:** Honeypots, IDSs, SIEM.
 3. **Administrative Detective Controls:** Review access rights, Audit Log Monitoring, and unauthorized changes detection.

Control Functions: Corrective Controls

- ❖ **Corrective controls** include any measures taken to repair damage or restore resources and capabilities to their prior state following an unauthorized or unwanted activity.
- ❖ **Corrective controls** attempt to reverse the impact of an incident. After a problem happens in a process.
- ❖ Examples include:
 1. **Physical Corrective Controls:** Repair physical damage, re-issue access cards.
 2. **Technical Corrective Controls:** patching a system, quarantining a virus, terminating a process, or rebooting a system, Backups and System Recovery.
 3. **Administrative Corrective Controls:** Putting an incident response plan into action.

Security Control Type V. Security Control Function

		CONTROL FUNCTIONS		
		Preventative	Detective	Corrective
CONTROL TYPES	Physical	Fences, gates, locks	CCTV and surveillance camera logs	Repair physical damage, re-issue access cards
	Technical	Firewall, IPS, MFA solution, antivirus software	Intrusion detection systems, honeypots	Patch a system, terminate a process, reboot a system, quarantine a virus
	Administrative	Hiring and termination policies, separation of duties, data classification	Review access rights, audit logs, and unauthorized changes	Implement a business continuity plan or incident response plan

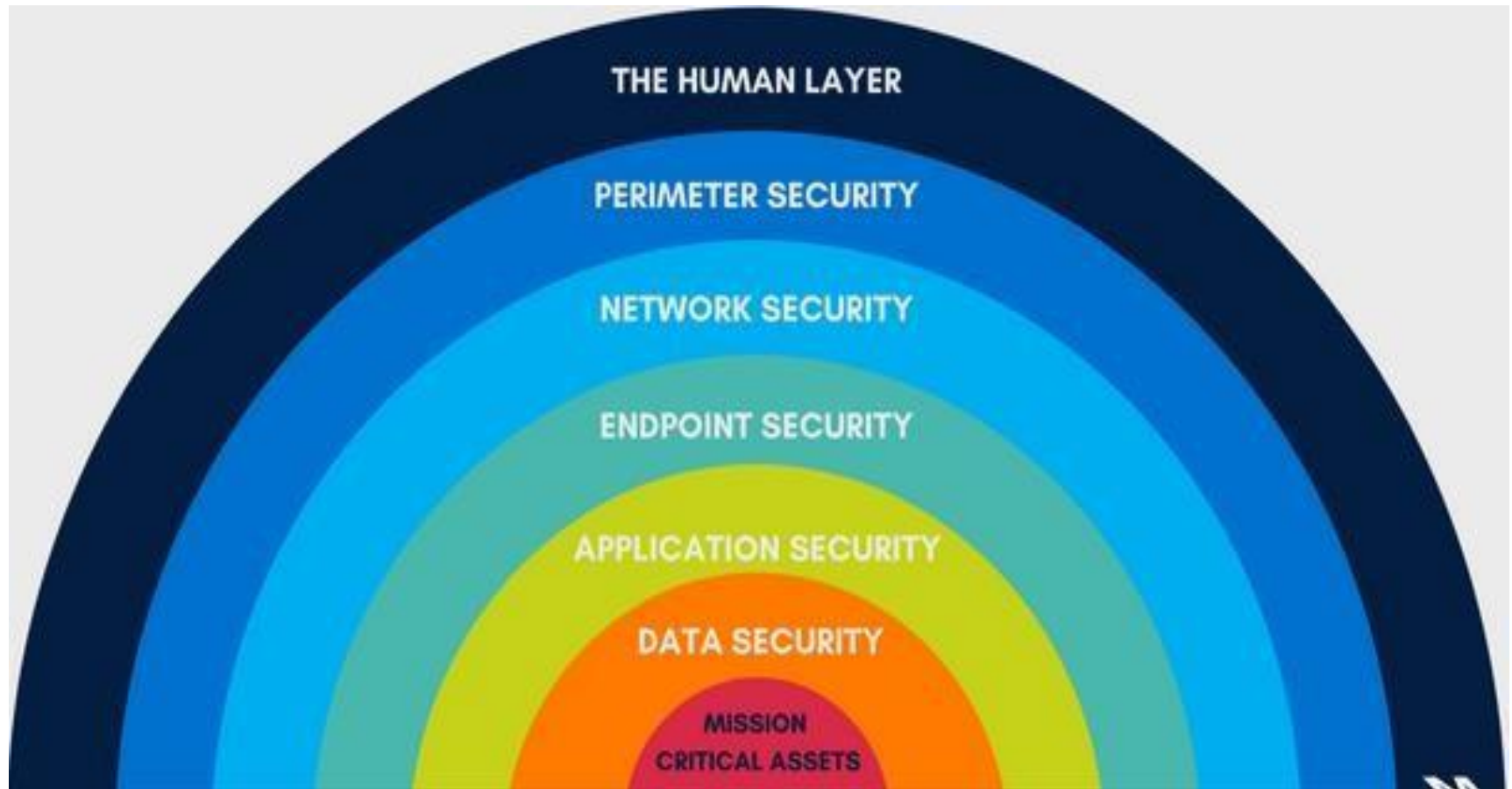
Control Functions: Others

- ❖ **Preventive controls** attempt to prevent an incident from occurring.
- ❖ **Detective controls** attempt to detect incidents after they have occurred.
- ❖ **Corrective controls** attempt to reverse the impact of an incident.
- ❖ **Deterrent controls** attempt to **discourage** individuals from causing an incident.
- ❖ **Compensating controls** are alternative controls used when a primary control is not feasible.

Control Functions: Others

- ❖ **Deterrent controls** attempt to **discourage** individuals from causing an incident.
 - ✓ A Deterrent control is anything intended to warn a would-be attacker that they should not attack. This could be a **posted warning notice** that they will be prosecuted to the fullest extent of the law, locks on doors, barricades, lighting, Dogs, alarms or anything can delay or discourage an attack which includes Cable Locks, Hardware Locks, Video surveillance & guards.
- ❖ **Compensating controls** are alternative controls used when a primary control is not feasible.

Layering Security Controls

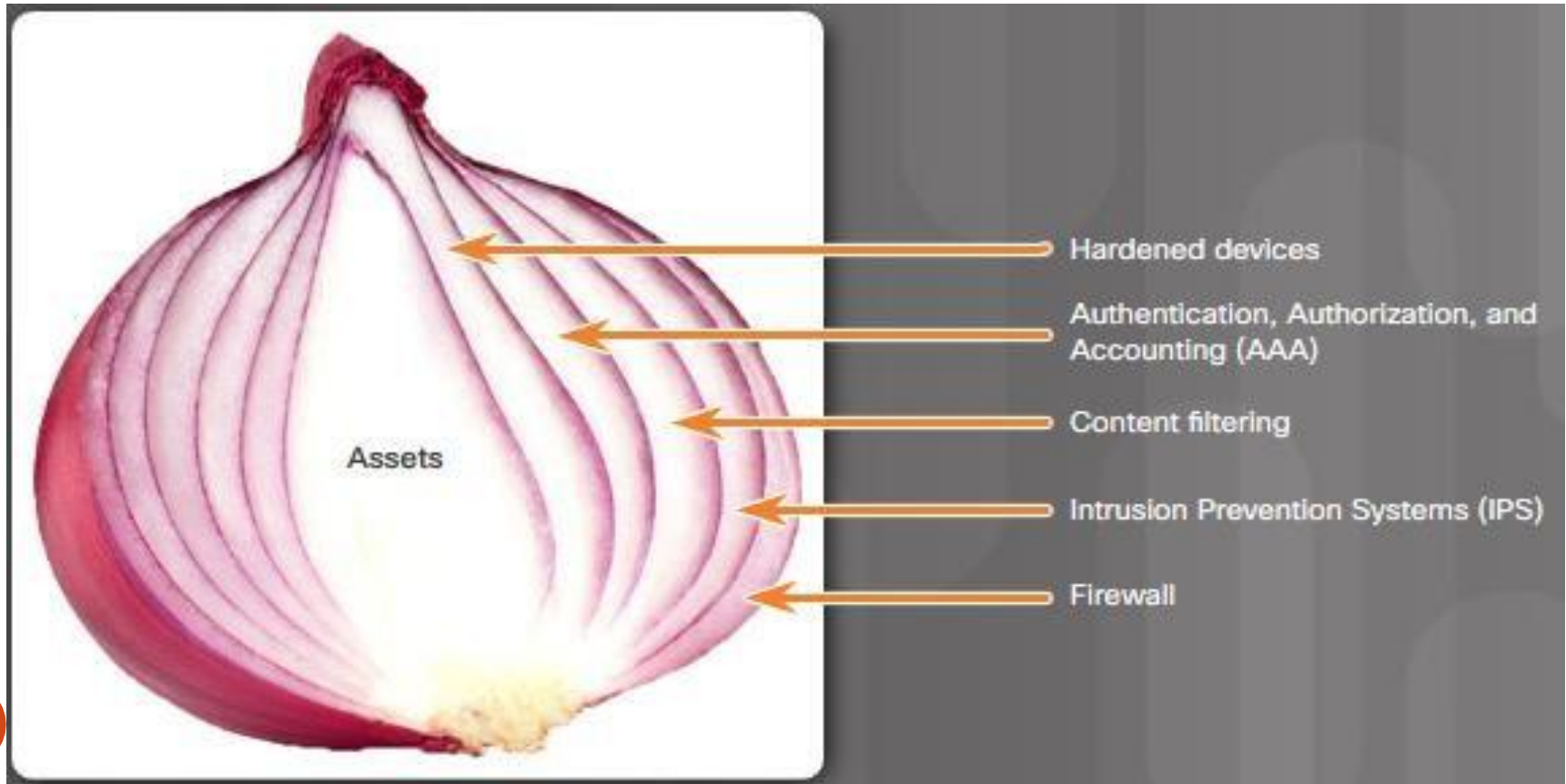


Layering Security Controls

- ❖ Layering is an approach that combines multiple security controls to develop what's called a **defense-in-depth strategy**.
- ❖ Defense-in-depth is a common strategy used in cyber security whereby multiple layers of controls are implemented.
- ❖ By combining controls into multiple layers of security you ensure that if one layer fails to counteract a threat that other layers will help to prevent a breach in your systems.
- ❖ The **security onion** analogy illustrates a layered approach to security.

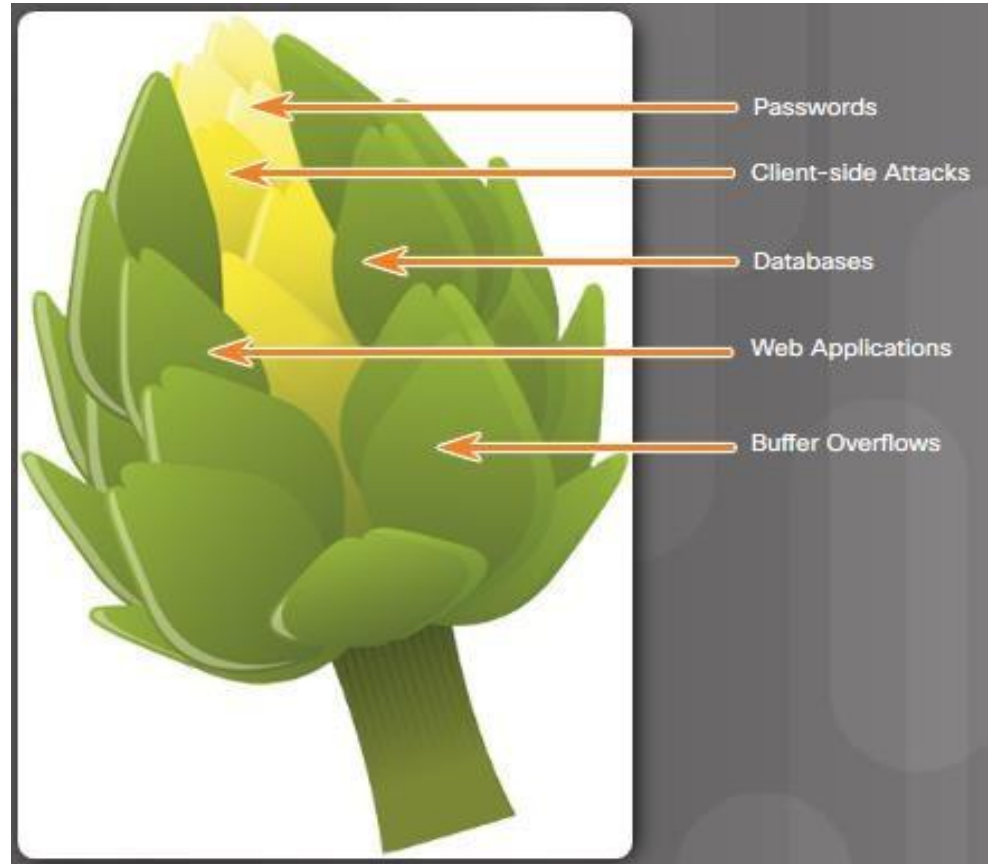
Security Onion Approaches

- ❖ The **security onion** analogy illustrates a layered approach to security.
- ❖ A threat actor would have to peel away at a network's defense mechanisms one layer at a time.



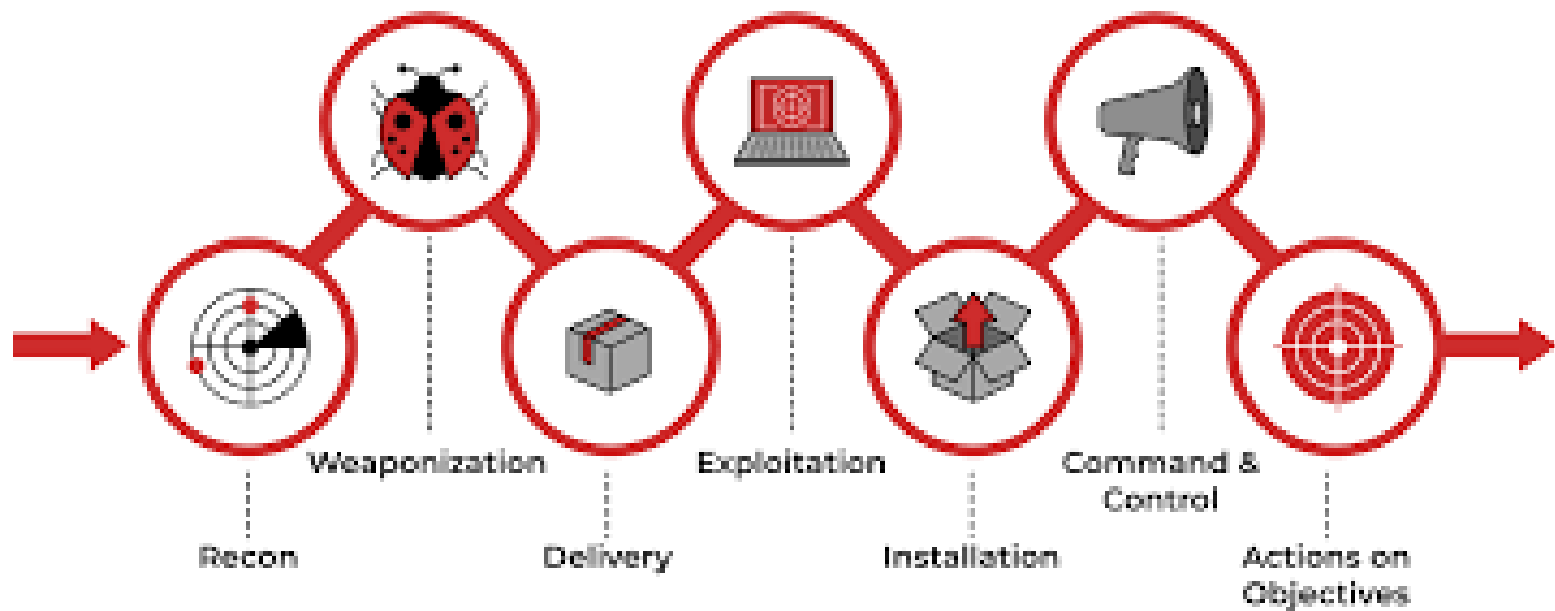
Security Onion and Security Artichoke Approaches

- ❖ However, with the evolution of borderless networks, a **security artichoke** is a better analogy.
- ❖ Threat actors may only need to remove certain “artichoke leaves” to access sensitive data.
- ❖ For example, a **mobile device** is a leaf that, when compromised, may give the threat actor access to sensitive information such as corporate email.



- ❖ The key difference between security artichoke from security onion is that not every leaf needs to be removed in order to get at the data.

The Cyber Kill Chain



The Cyber Kill Chain Model of Intrusion (Attack)

- ❖ The steps used by hackers to attack the IS systems help security analysts understand the techniques, tools, and procedures of threat actors.
- ❖ The threat actor gains more access to the target as they progress through the steps.
- ❖ The goal of security analysts is **to stop** them as early as possible to lessen the damage done.

The Cyber Kill Chain

Steps of the Cyber Kill Chain®

- ❖ Developed by **Lockheed Martin** to identify and prevent cyber intrusions.
 - ✓ The steps of the Cyber Kill Chain help analysts understand the techniques, tools, and procedures of threat actors.
 - ✓ The threat actor gains more access to the target as they progress through the steps.
 - ✓ The goal is **to stop** them as early as possible to lessen the damage done.

Steps of the Cyber Kill Chain



The Cyber Kill Chain: (1) Reconnaissance

- ❖ **Reconnaissance** is when the threat actor performs research, gathers intelligence, and selects targets.
- ❖ Organizations may provide information on websites, public-facing network devices, in news articles, conference proceedings, and social media outlets.

Adversary Tactics	SOC Defenses
Plan and conduct research: • Harvest email addresses • Identify employees on social media networks • Collect all public relations information (press releases, awards, conference attendees, etc.) • Discover Internet-facing servers	Discover Adversary's Intent: • Web log alerts and historical searching data • Data mine browser analytics • Build playbooks for detecting browser behavior that indicate recon activity • Prioritize defense around technologies and people that recon activity is targeting

- ❖ Security Operations Centers (SOCs) provide a broad range of services: Monitoring, Management, Comprehensive threat solutions, Hosted security

The Cyber Kill Chain: (2) Weaponization

- ❖ **Weaponization** uses the vulnerability information gathered in the reconnaissance step to identify and develop a weapon against specific targeted systems in the organization.

Adversary Tactics	SOC Defenses
Prepare and stage the operation: • Obtain an automated tool to deliver the malware payload (weaponizer). • Select or create a document to present to the victim. • Select backdoor and command and control infrastructure.	Detect and collect weaponization artifacts: • Conduct full malware analysis. • Build detections for the behavior of known weaponizers. • Is malware old, "off the shelf" or new malware that might indicate a tailored attack? • Collect files and metadata for future analysis. • Determine which weaponizer artifacts are common to which campaigns.

The Cyber Kill Chain: (3) Delivery

❖ **Delivery** is when the threat actor delivers the developed weapon using either a website, a removable USB media, or an email attachment.

Adversary Tactics	SOC Defenses
Launch malware at target: • Direct against web servers • Indirect delivery through: • Malicious email • Malware on USB stick • Social media interactions • Compromised websites	Block delivery of malware: • Analyze the infrastructure path used for delivery. • Understand targeted servers, people, and data available to attack. • Infer intent of the adversary based on targeting. • Collect email and web logs for forensic reconstruction.

The Cyber Kill Chain: (4) Exploitation

- ❖ **Exploitation** is when the threat actor triggers the weapon and executes it to compromise the vulnerability and gain control of the target.

Adversary Tactics	SOC Defenses
Exploit a vulnerability to gain access: • Use a software, hardware, or human vulnerability • Acquire or develop the exploit • Use an adversary-triggered exploit for server vulnerabilities • Use a victim-triggered exploit such as opening an email attachment or a malicious web link	Train employees, secure code, and harden devices: • Employee awareness training and email testing • Web developer training for securing code • Regular vulnerability scanning and penetration testing • Endpoint hardening measures • Endpoint auditing to forensically determine origin of exploit

The Cyber Kill Chain: (5) Installation

- ❖ **Installation** is when the threat actor establishes a back door into the system to allow for continued access to the target.

Adversary Tactics	SOC Defenses
Install persistent backdoor: • Install webshell on web server for persistent access. • Create point of persistence by adding services, AutoRun keys, etc. • Some adversaries modify the timestamp of the malware to make it appear as part of the operating system.	Detect, log, and analyze installation activity: • HIPS to alert or block on common installation paths. • Determine if malware requires admin privileges or only user. • Endpoint auditing to discover abnormal file creations. • Determine if malware is known threat or a new variant.

- ❖ **HIPS: Host-based Intrusion Prevention System** used to protect endpoint devices.

The Cyber Kill Chain: (6) Command & Control

- ❖ **Command & Control (CnC or C2)** is when an outside server channel is used by the threat actor to manipulate a target by issuing commands to the software that they installed on the target.

Adversary Tactics	SOC Defenses
Open channel for target manipulation: • Open two way communications channel to CnC infrastructure. • Most common CnC channels are over web, DNS, and email protocols. • CnC infrastructure may be adversary owned or another victim network itself.	Last chance to block operation: • Research possible new CnC infrastructures. • Discover CnC infrastructure thorough malware analysis. • Prevent impact by blocking or disabling CnC channel. • Consolidate the number of Internet points of presence. • Customize blocks of CnC protocols on web proxies.

The Cyber Kill Chain: (7) Actions on Objectives

- ❖ **Actions on Objectives** is the final step of the kill chain and is when the attacker achieves attack objective.
 - ✓ Can be used for data theft, performing a DDoS attack, or using the compromised network to create and send spam.
 - ✓ Threat actor is deeply rooted in the systems of the organization and may be extremely difficult to remove from the network.

Adversary Tactics	SOC Defenses
Reap the rewards of successful attack: • Collect user credentials. • Privilege escalation. • Internal reconnaissance. • Lateral movement through environment. • Collect and exfiltrate data. • Destroy systems. • Overwrite, modify, or corrupt data.	Detect by using forensic evidence: • Establish incident response playbook. • Detect data exfiltration, lateral movement, and unauthorized credential usage. • Immediate analyst response for all alerts. • Forensic analysis of endpoints for rapid triage. • Network packet captures to recreate activity. • Conduct damage assessment.

The Diamond Model of Intrusion (Attack)

Diamond Model Overview

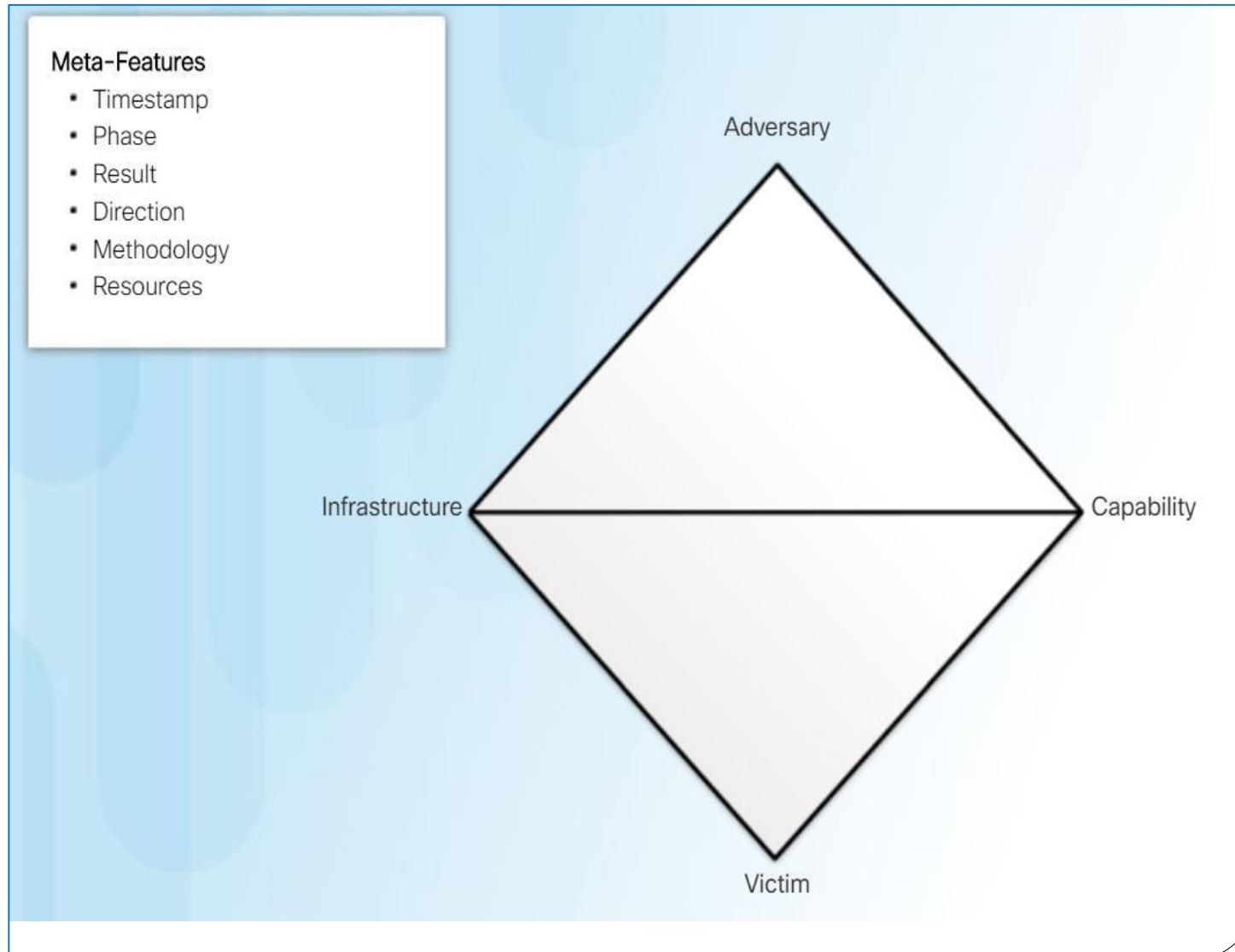
- ❖ The Diamond Model identifies four parts involved in a security incident.
 1. **Adversary** – Parties responsible for the intrusion.
 2. **Capability** – Tool or technique used by the threat actor.
 3. **Infrastructure** – The network path(s) used by the threat actor to establish and maintain command and control.
 4. **Victim** – The target of the attack. The victim could then be used as part of the infrastructure to launch other attacks.
- ❖ The *adversary* uses *capabilities* over *infrastructure* to attack the *victim*.

The Diamond Model of Intrusion (Attack)

Diamond Model Overview

Each line in the model shows how each part reached the other.

Meta-features expand the model to include important elements.

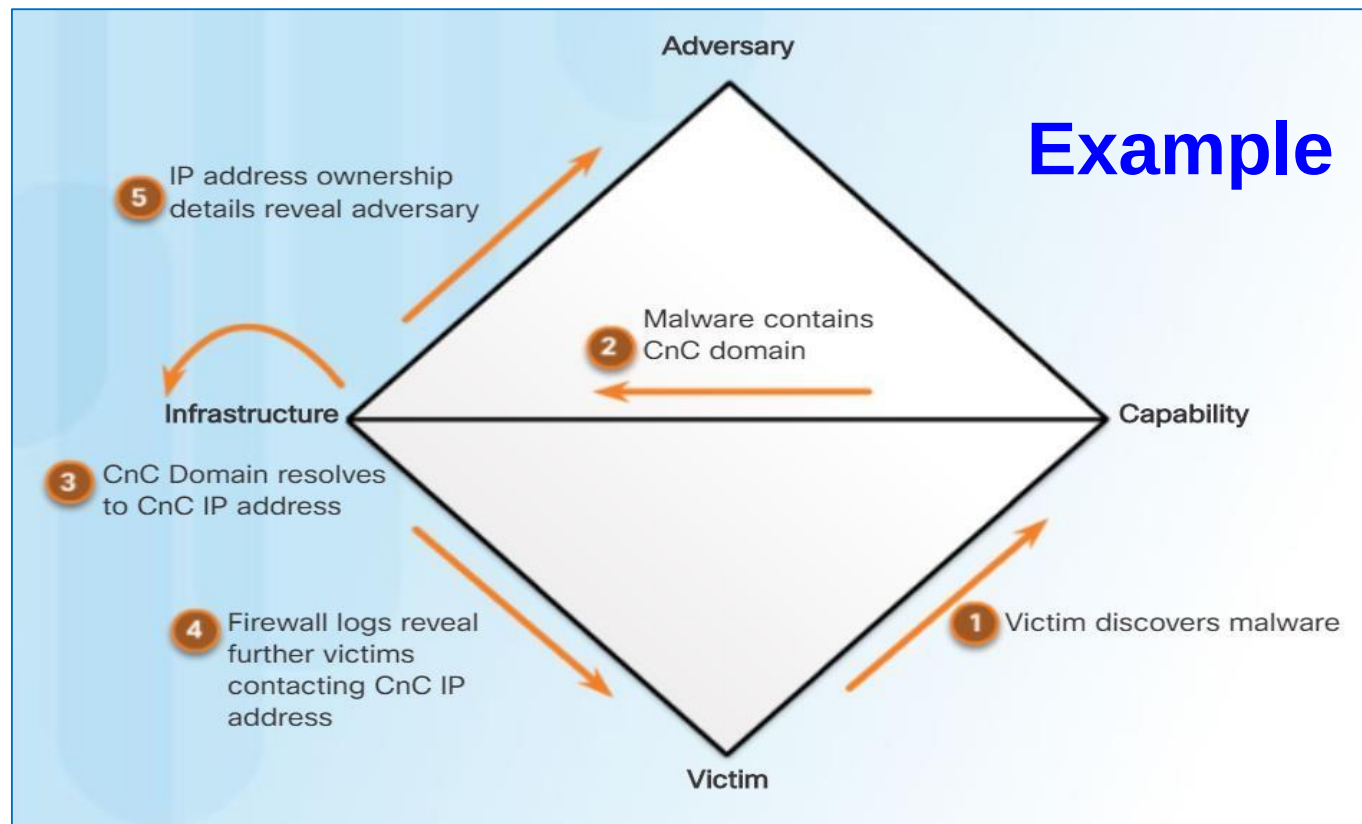


The Diamond Model of Intrusion (Attack)

Pivoting Across the Diamond Model

❖ Each line in the model shows how each part reached the other.

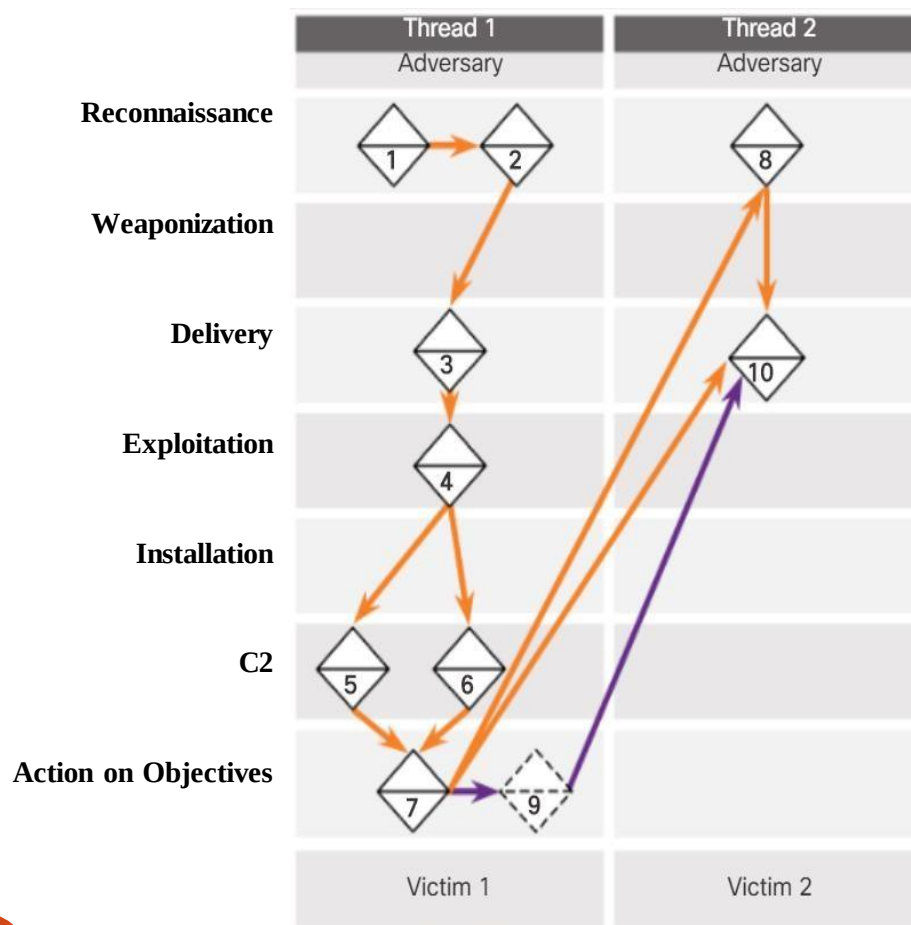
❖ The Diamond Model is ideal for illustrating how the adversary pivots from one event to the next.



- 1) An employee reports that his computer is acting abnormally and a scan indicates the computer is infected with malware.
- 2) An analysis of the malware reveals that the malware contains a list of CnC domain names.
- 3) These domain names resolve to a list of IP addresses.
- 4) These IP addresses are used to investigate logs to determine if other victims in the organization are using the CnC channel.
- 5) The IP addresses are also used to identify the adversary.

The Diamond Model and the Cyber Kill Chain

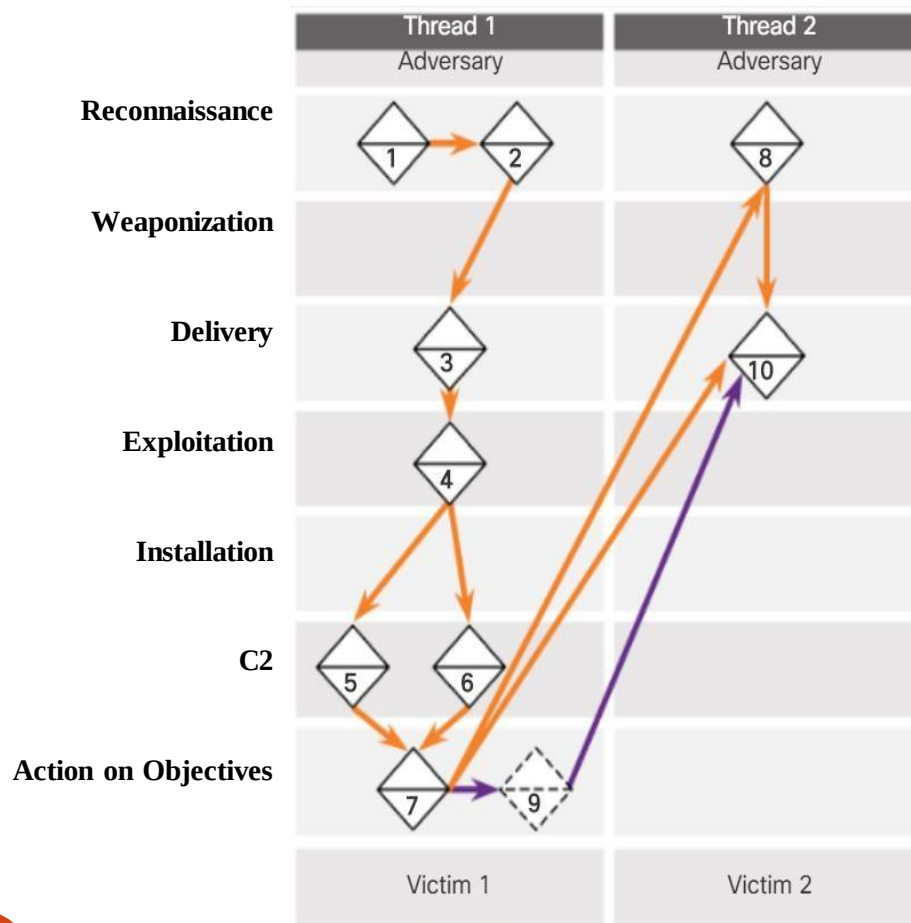
❖ The example illustrates the process used by an **adversary** as they traverse the Cyber Kill Chain.



1. Adversary conducts a web search for victim company Gadgets, Inc. receiving as part of the results their domain gadgets.com.
2. Adversary searches “network administrator gadget.com” and discovers the network administrators’ email addresses.
3. Adversary sends phishing emails with a Trojan horse attached to the network administrators.
4. One network administrator (NA1) opens the malicious attachment which executes the enclosed exploit.
5. NA1’s host registers with a CnC controller by sending an HTTP Post message and receiving an HTTP Response in return.
6. Analysis of the malware identifies additional backup IP addresses.
7. Through a CnC HTTP response message sent to NA1’s host, the malware begins to act as a proxy for new TCP connections.

The Diamond Model and the Cyber Kill Chain

- ❖ The example illustrates the process used by an adversary as they traverse the Cyber Kill Chain.



- Through the proxy established on NA1's host, Adversary does a web search for "most important research ever" and finds Victim 2, Interesting Research Inc.
- Adversary checks NA1's email contact list for any contacts from Interesting Research Inc. and discovers the contact for the Interesting Research Inc. Chief Research Officer.
- Chief Research Officer of Interesting Research Inc. receives a spear-phish email from Gadget Inc.'s NA1's email address sent from NA1's host with the same payload as observed in Event 3.

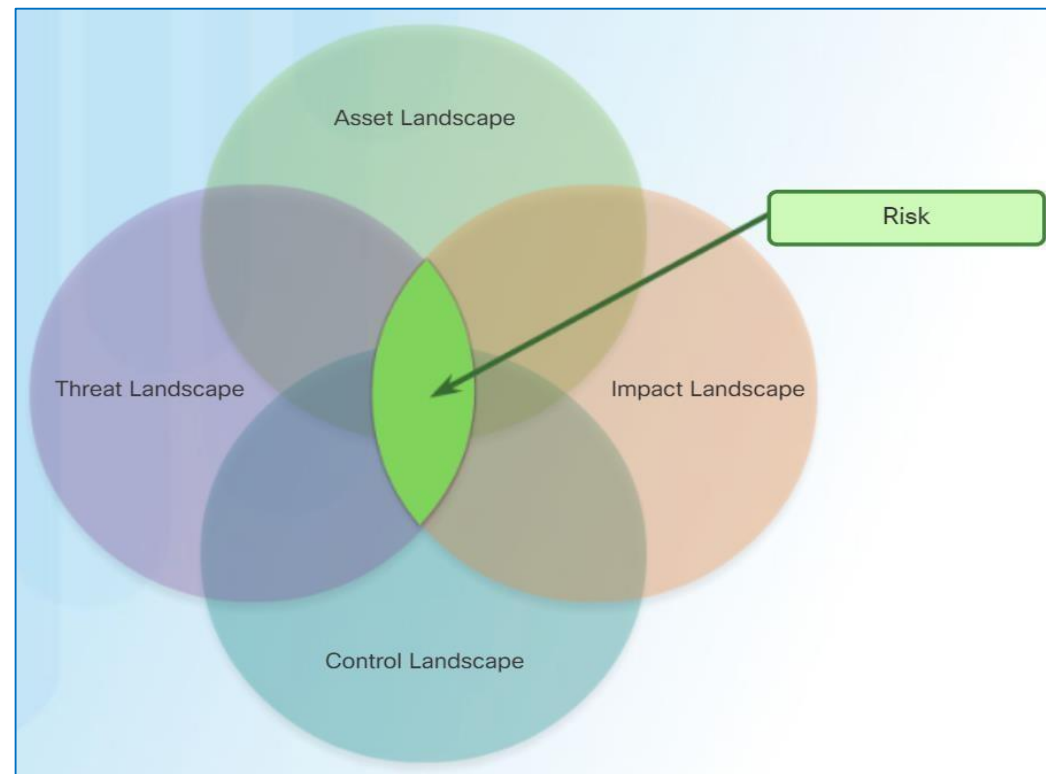
The adversary now has two compromised victims from which additional attacks can be launched.

Security Incidents



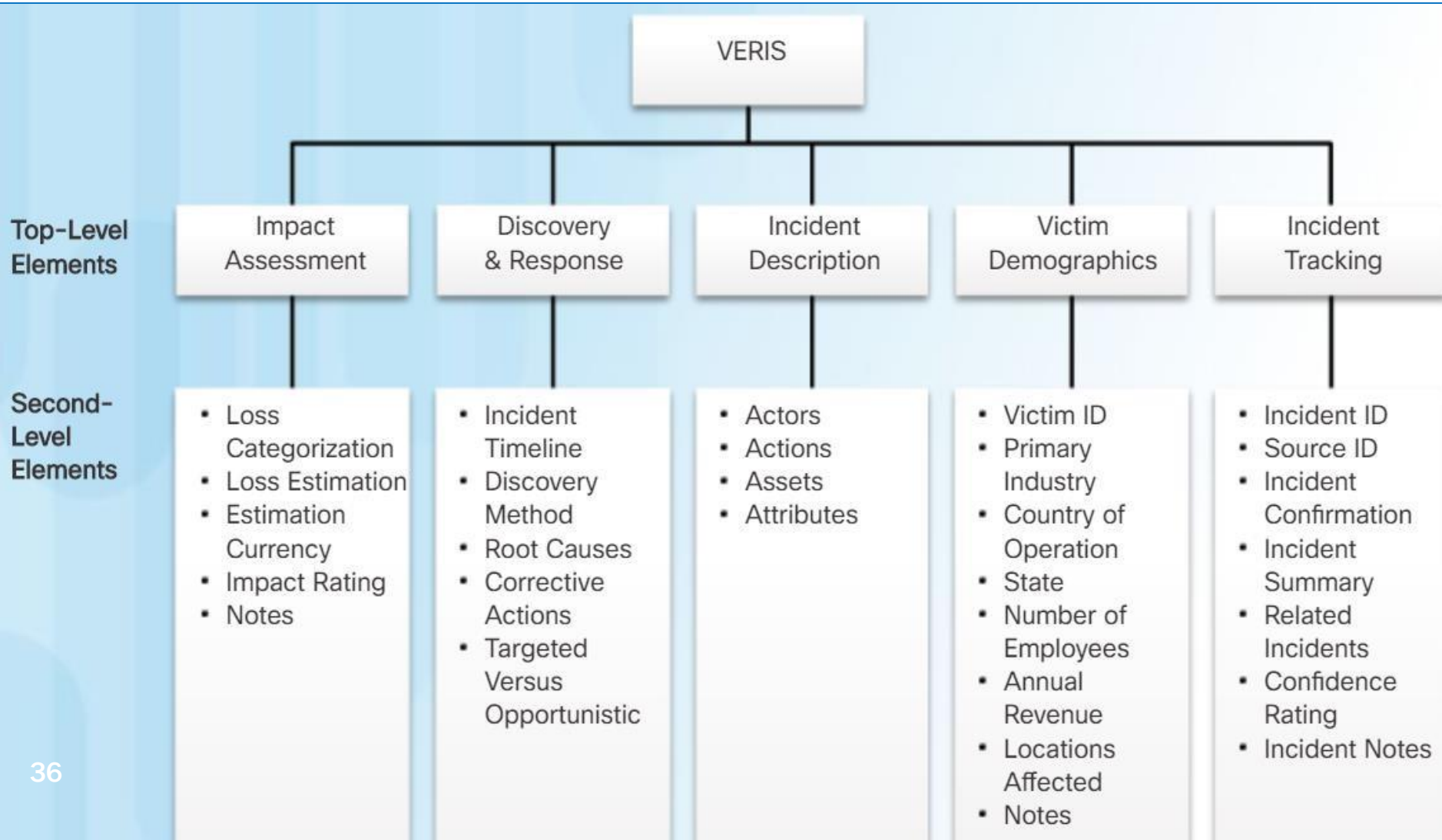
The VERIS Schema: What is the VERIS Schema?

- ❖ Vocabulary for Event Recording and Incident Sharing (VERIS) schema/Framework is a set of metrics to describe security incidents in a structured way.
 - ✓ **A taxonomy that standardizes how security incidents are described and categorized.**
- ❖ In the VERIS schema, risk is defined as the intersection of four landscapes of **Threat**, **Asset**, **Impact**, and **Control**.
- ❖ Information from each landscape helps to understand the level of risk to the organization.



The VERIS Schema: Top-Level and Second-Level Elements

- ❖ The VERIS Schema identifies five top-level elements, providing a different aspect of the incident.



The VERIS Schema: Top-Level and Second-Level Elements

- ❖ The VERIS Schema identifies five top-level elements, providing a different aspect of the incident.
 - ✓ Each top-level element contains several second-level elements for classifying collected incident data.
- 1. **Impact Assessment** – All incidents have an impact, whether it is minor or widespread, which can only be determined after an incident has occurred.
- 2. **Discovery and Response** – Identifies the timeline of events, the method of incident discovery, and what the response was to the incident, including how it was remediated.
- 3. **Incident Description** - Describes an incident completely, using the A4 threat model developed by Verizon.
- 4. **Victim Demographics** – Describes the organization that has experienced the incident and its characteristics.
- 5. **Incident Tracking** – Records general information about the incident so organizations can identify, store, and retrieve incidents over time.

The VERIS Schema: Create a VERIS Record

- ❖ When creating records to add to the database, start with the basic facts about the incident and use the VERIS elements outlined by the community.
 - ✓ The only required fields in the record are those where the attribute is present.
 - ✓ As more is known about the incident, data can be added.
- ❖ Additional information can be recorded by adding VERIS labels to the existing record.

Variable	Value
timeline.incident.year	2017
schema_version	1.3
incident_id	1
security_incident	Confirmed
discovery_method	Unknown
action	Unknown
asset	Unknown
actor	Unknown
attribute	Unknown

timeline.incident.year	2017
timeline.incident.month	06
timeline.incident.day	20

summary Computer was infected with malware

discovery.notes	Reported by Debbie in sales
malware.notes	rootkit was found on Debbie's computer
social.notes	Debbie brought in an infected USB drive and used it on her company laptop

The VERIS Schema: The VERIS Community Database

The screenshot displays the GitHub interface for the repository **vz-risk / VCDB**. At the top, navigation links include Features, Business, Explore, Marketplace, and Pricing. A search bar and a link to 'Sign in or Sign up' are also present. Below the repository name, statistics show 60 Watchers, 151 Stars, and 68 Forks. The main navigation bar includes tabs for Code, Issues (4,645), Pull requests (1), Projects (0), Wiki, and Insights.

The repository is titled **VERIS Community Database**. It has 379 commits, 4 branches, 4 releases, and 10 contributors. A 'Branch: master' dropdown and a 'New pull request' button are visible. A 'Find file' button and a green 'Clone or download' button are also present.

The commit history shows the latest commit by **swidup** with the message 'Revert "another update 2"' on Nov 14, 2016. Below this, a list of files and their commit messages is shown:

File	Commit Message	Time Ago
data	Revert "another update 2"	3 months ago
figure	Fixed invalid year, updated Readme and CSV	4 years ago
tools	Small changes	8 months ago
.gitignore	updates the gitignore file to exclude ipython notebook	3 years ago
LICENSE.txt	adds license file.	3 years ago
README.Rmd	updated Readme. removing ref to code.	4 years ago
README.html	updated Readme. removing ref to code.	4 years ago
README.md	added vcdb schema	a year ago

The VERIS Schema: The VERIS Community Database...

- ❖ The VERIS Community Database (VCDB) is a very useful shared database for organizations willing to participate.
 - ✓ Organizations can submit security incident details to the VCDB for the community to use.
 - ✓ The larger and more robust the VCDB becomes, the more useful it will be in prevention, detection, and remediation of security incidents.
 - ✓ It will also become a very useful tool for risk management, saving organizations data, time, effort, and money.

Who Are the Cyber Criminals?

- ❖ In the early years of the cybersecurity world, the typical cyber criminals were teenagers or hobbyists operating from a home PC, with attacks mostly limited to pranks and vandalism.
- ❖ Today, the world of the cyber criminals has become more dangerous.
- ❖ Attackers are individuals or groups who attempt to exploit vulnerabilities for personal or financial gain.
- ❖ Cyber criminals are interested in everything from credit cards to product designs, and anything with value.

Thwarting Cyber Criminals

- ❖ Thwarting the cyber criminals is a difficult task and there is no such thing as a “silver bullet.”
- ❖ However, company, government and international organizations have begun to take coordinated actions to limit or fend off cyber criminals.
- ❖ The coordinated actions include:
 1. Creating comprehensive databases of known system vulnerabilities and attack signatures
 2. Establishing early warning sensors and alert networks
 3. Sharing cyber intelligence information.
 4. Establishing information security management standards
 5. Enacting new laws to discourage cyberattacks and data breaches

Thwarting Cyber Criminals

1. Creating comprehensive databases of known system vulnerabilities and attack signatures (a unique arrangement of information used to identify an attacker's attempt to exploit a known vulnerability). Organizations share these databases worldwide to help prepare for and fend off many common attacks.
 - ✓ Vulnerability databases: the USA national common vulnerabilities and exposures (CVE) database is an example of the development of a national database.
<http://www.cvedetails.com/>

Thwarting Cyber Criminals

2. Establishing early warning sensors and alert networks. Due to cost and the impossibility of monitoring every network, organizations monitor high-value targets or create imposters that look like high-value targets. Because these high-value targets are more likely to experience attacks, they warn others of potential attacks.
 - ✓ The honeynet project is an example of creating early warning systems. The project provides a HoneyMap which display real-time visualization of attacks.
<https://www.honeynet.org/node/960>

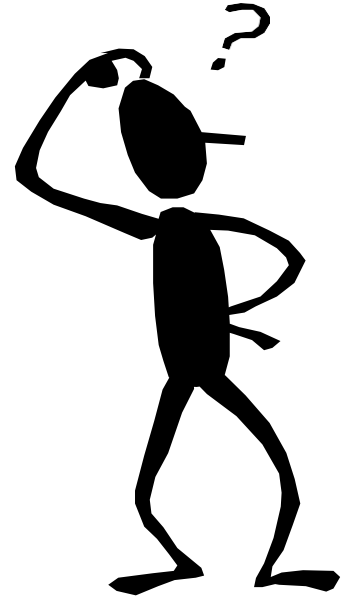
Thwarting Cyber Criminals

3. Sharing cyber intelligence information. Business, government agencies and countries now collaborate to share critical information about serious attacks to critical targets in order to prevent similar attacks in other places. Many countries have established cyber intelligence agencies to collaborate worldwide in combating major cyberattacks.
 - ✓ InfraGard is an example of wide spread sharing of cyber intelligence. The InfraGard program is a partnership between the FBI and the private sector. The participants are dedicated to sharing information and intelligence to prevent hostile cyberattacks. <https://www.infragard.org/>

Thwarting Cyber Criminals

4. Establishing information security management standards among national and international organizations.
 - ✓ The ISO/IEC 27000 standard are an example of Information Security Management Standards. The standards provide a framework for implementing cybersecurity measures within an organization.
<http://www.27000.org/>
5. Enacting new laws to discourage cyberattacks and data breaches. These laws have severe penalties to punish cyber criminals caught carrying out illegal actions.
 - ✓ Cybercrime Act, 2015

THANK YOU



END

ET 8202: LECTURE 08